

Modernising Payment Services Regulation

Consultation response

HM Treasury · Payments and Fintech team · Consultation closes 6 October 2026

Respondent: Matthew T. Kirby, independent researcher — matthew.kirby@driftlayer.org · driftlayer.org. I consent to publication of this response with attribution.

Scope: Questions 15, 16, 17, 18 and 42, with reference to paragraph 4.12 and Question 21.

Declaration of interest. I filed US provisional application 64/141,321 on 26 August 2026 on a mechanism in this area. The specification is published openly as *Mandate Lifecycle Extensions for Agentic Payment Credentials*, Technical Disclosure Commons, Defensive Publications Series no. 11517 (August 2026), under CC BY 4.0, with a reference implementation at github.com/MandatePatch/mandatepatch under Apache-2.0. I have an interest in this subject and state it here so the Government can weigh what follows. I submitted a response to the Bank of England's consultation on the design of the future retail payments infrastructure on 9 September 2026; that response addressed infrastructure, and this one addresses regulation. Nothing I recommend below requires anyone to license anything from me, and the definitions I offer in answer to Question 42 are free and citable by anyone.

Summary

Paragraph 3.35 states that the PSRs “were designed before the development of AI and may not fully facilitate the use of agentic AI.” I agree, and I would locate the difficulty precisely.

The payment services framework assumes that the act of consenting and the act of paying are close together in time, and that what the payer consented to can be reconstructed from the transaction itself. Agentic payments break both assumptions. A standing instruction given in words on Monday may be executed by software on Friday, against a cart the payer has never seen.

The consequence for regulation is narrow and consequential. **A transaction can now satisfy every machine-enforced condition of a delegated authority while still raising a genuine question whether the payer consented to the transaction ultimately executed.** The PSRs contain a legal test for that question. The payment record may not contain the evidence needed to answer it.

My recommendation is not that the Government mandate a mechanism. It is that regulation should require that the question “*was this within the payer's authority?*” be answerable — which means requiring that the evidence needed to answer it is produced at the time authority is given and retained through the period in which a dispute may arise. And it should require that it be countable, because a liability regime that cannot be measured cannot be calibrated.

Question 15 — how existing regulation needs to adapt

The consenting act has moved

Strong customer authentication and dynamic linking were designed around a payer who is present. Dynamic linking binds an authentication code to a specific amount and a specific payee, so that a

change to either invalidates it. That is a sound rule, and it answers the question it was built to answer: *is the person who authenticated the person who is paying, and are they paying what they think they are paying?*

What it does not reach is meaning. A payer who instructs an agent to buy “the usual weekly groceries, up to £150, from the usual supermarket” has consented to a description. The enforceable fields are an amount and a merchant. Everything that makes the instruction a grocery order rather than a licence to spend £150 at that shop is carried as context and not enforced.

This is not a hypothetical distinction. It is already visible in the operative rules of a deployed scheme. The Visa Core Rules, in the public edition dated 18 April 2026, set out when an incremental authorisation against a live estimated authorisation requires fresh strong customer authentication:

“For a Transaction initiated in a Card-Present Environment, a Merchant must obtain Strong Customer Authentication (SCA) for an Incremental Authorization Request when both: • The initial Estimated Authorization Request is below the Visa Easy Payment Service (VEPS) limit ... and the Merchant did not obtain SCA. • The subsequent Incremental Authorization Request takes the total authorized Transaction amount above the VEPS limit.”

Visa Core Rules and Visa Product and Service Rules, §5.7.2.5 (public edition dated 18 April 2026).

The trigger for bringing the customer back is a **cumulative amount crossing a threshold**. Nothing in that rule asks whether what is being bought has changed. That is the correct design for the world it was written for — a merchant incrementing a hotel folio — and it is a precise illustration of what does not carry across to an agent acting on a described instruction.

So there is a class of transaction the framework cannot currently characterise

Consider an agent that, facing an out-of-stock item, substitutes a package four times the size. The amount is within the cap. The merchant is correct. The payer authenticated, days earlier, to a standing authority that permits exactly this spend at exactly this shop.

Every machine-enforced constraint is satisfied. Whether the transaction was authorised is a different question, and the Payment Services Regulations 2017 already ask it in the right terms.

“A payment transaction is to be regarded as having been authorised by the payer for the purposes of this Part only if the payer has given its consent to— (a) the execution of the payment transaction; or (b) the execution of a series of payment transactions of which that payment transaction forms part.”

Payment Services Regulations 2017, reg. 67(1).

Where a standing instruction constitutes the payer’s consent to a series of payment transactions, the legal question is whether that consent extended to the substituted transaction — a question about the scope of an earlier consent, not about whether a credential was presented correctly.

The framework already separates those two things, and already places the burden:

“Where a payment service user denies having authorised an executed payment transaction, the use of a payment instrument recorded by the payment service provider, including a payment initiation service provider where appropriate, is not in itself necessarily sufficient to prove either that— (a) the payment transaction was authorised by the payer...”

Payment Services Regulations 2017, reg. 75(3); and see reg. 75(1) (burden on the payment service provider to prove authentication and accurate recording).

And the refund obligation is keyed directly to that consent test, with no residual category between its two outcomes:

“Subject to regulations 74 and 75, where an executed payment transaction was not authorised in accordance with regulation 67 (consent and withdrawal of consent), the payment service provider must— (a) refund the amount of the unauthorised payment transaction to the payer...”

Payment Services Regulations 2017, reg. 76(1).

I would put the difficulty as plainly as I can. **The provisions are not wrong. They already ask whether the payer consented to this transaction or to a series including it, and they already say that authentication is not proof of authorisation.** What has changed is that, for a payment initiated by software under an instruction given days earlier, **neither side can produce the evidence that test requires** — because nothing in the record establishes what the series was scoped to, or what was evaluated against it before the money moved.

The result is not that the law resolves the case wrongly. It is that the case cannot be resolved on evidence, and a dispute that cannot be resolved on evidence tends to be resolved by whoever holds the record — which today is the platform, not the payer and not the payment service provider carrying the statutory burden.

The available operational outcomes today are all poor. The transaction proceeds silently, and the deviation is indistinguishable in the record from approved practice. Or it is declined outright, and the payer receives nothing. Or the standing authority is revoked and rebuilt, which is disproportionate to a change of pack size and destroys the arrangement the payer set up. None of the three produces a record of what the payer actually agreed to.

And the timing provisions do not help

Regulation 67(3) lets the payer withdraw consent “at any time before the point at which the payment order can no longer be revoked under regulation 83.” Regulation 83(2) fixes that point:

“In the case of a payment transaction initiated by a payment initiation service provider, or by or through the payee, the payer may not revoke the payment order after giving consent to the payment initiation service provider to initiate the payment transaction...”

Payment Services Regulations 2017, regs. 67(3)–(4) and 83(2).

For a conventional payment initiation, consent and initiation are adjacent and the rule is unremarkable. **Where the earlier standing authority also constitutes the relevant consent for regulation 83 purposes**, the timing rule becomes consequential: the point of irrevocability may fall before the software has resolved the later transaction against the payer’s instruction.

Regulation 67(4) permits withdrawal of consent to a series prospectively — “any future payment transactions are not regarded as authorised” — but **that does not itself provide a means of approving or rejecting a single divergent transaction while preserving the series**. That is the capability the framework does not describe, and it is why revoke-and-recreate is not simply one bank’s product decision.

The published protocols reach this boundary and stop

This is not a gap only I can see. The frameworks being built for agentic commerce name the moment and do not resolve it.

- **OpenAI and Stripe’s Agentic Commerce Protocol** defines a resolution field on its message schemas with the values recoverable, requires_buyer_input and requires_buyer_review — the last described in the specification as “buyer must authorize.” It recognises that execution should halt for the buyer. It does not define a signed artefact expressing the changed transaction the buyer then approved.
- **Google’s Universal Commerce Protocol**, in its AP2 Mandates extension, defines mandate_scope_mismatch, where “the mandate is bound to a different checkout.” The failure is named. No remedy is written in the same document.
- **Google’s Agent Payments Protocol**, in Human-Not-Present mode, has the user sign open mandates carrying constraints and the agent sign the closed checkout. It distinguishes original human authority from autonomous closure, and defines no object for narrowly approving an exception to the standing authority.

An independent security analysis of AP2, published in August 2026, reaches the same boundary from the other side. Across a systematic model of forty-eight threats spanning that protocol’s phases, trust boundaries and deployment architectures, the authors conclude:

“AP2 cannot reliably bind a past transaction to the trust and cryptographic state that existed when it occurred.”

Aviv, Gandh, Bitton and Shabtai, “Beyond the Mandate: A Systematic Security Analysis of the Agent Payments Protocol (AP2),” arXiv:2608.23858, submitted 24 August 2026.

I note, because it bears on how early the Government is in this: a full-text search of that paper returns no occurrence of *amend*, *supersede*, *lineage*, *suspend*, *revoke*, *epoch* or *state machine*. A systematic threat model of the leading agentic-payments protocol does not name the lifecycle of the authority as a subject. I do not claim from this that nobody is working on it — standards discussion of delegation, revocation and auditability is active — only that the vocabulary is fragmented enough that a dedicated security analysis of this protocol did not reach for it.

The United Kingdom already has a live instance of this

The difficulty is not confined to card rails or to protocols being drafted abroad. Variable recurring payments are a UK standing authority with machine-enforced limits, and the same shape appears.

Under the Open Banking Read/Write Standard v4.0, where a payment would breach one or more of a variable recurring payment consent’s ControlParameters, the ASPSP must return an error — code U014 in that version — identifying the offending control parameter in the Field element. That is a real, machine-readable evaluation of a proposed payment against a standing authority, and one of the clearest in deployment anywhere.

What follows the evaluation is the gap. One participating bank’s published guidance states the position plainly:

“You cannot amend an active payment (sweeping and / or VRP), if you want to change an existing permission you must revoke and set-up a new one.”

NatWest, “How do I amend a VRP (variable recurring payment) or sweeping payment?”, published guidance, read 13 September 2026. I cite this as one institution’s description of its own product, not as a statement of what the specification permits.

So the evaluation exists, and the remedy is to destroy the authority and rebuild it. The evidence does not travel either. The Faster Payments mapping identifies the payment type — field 61.1 carries a “V” prefix for FPS transactions initiated by a PISP for sweeping and cVRP, and field 122 identifies the PISP — but ConsentId, the identifier of the consent against which the ASPSP evaluated the payment,

appears in none of the mapping tables to ISO 8583, Bacs Standard 18 or MT103. Faster Payments can know what kind of payment this is without knowing which authority it satisfied.

What this means for “liability for unauthorised payment transactions”

Question 15 asks whether the unauthorised-transaction provisions need updating. I would put the difficulty this way: those provisions turn on whether a transaction was authorised, and for an agent-initiated payment that is no longer a question about a moment. It is a question about whether execution stayed inside an authority granted earlier — and that can only be answered if someone recorded what the authority was, and what the execution was, in a form a third party can check.

The International Monetary Fund reaches the same place in its April 2026 note on agentic payments, which treats legal uncertainty and the allocation of liability as among the central unresolved questions once authorisation becomes mandate-based rather than contemporaneous with the transaction. I summarise its position rather than quote it, because I have not been able to verify a specific sentence against the published text.

So does the merchant side. In its position statement to the W3C workshop on e-commerce agents in September 2026, the Merchant Advisory Group argued that the evidence supporting an agentic transaction should be generated at authorisation and preserved through the dispute window — that is, that it must exist before the dispute, not be assembled after it. And the joint Digital Threat Report 2025-26 (BFSI Sector), issued by CERT-In, CSIRT-Fin and SISA, recommends that institutions “mandate human-in-the-loop controls for agentic AI actions above defined financial thresholds, with full audit trails.”

Different parties, in different postures, arrive at the same requirement: the evidence has to exist at the moment authority is exercised, not be reconstructed afterwards from platform logs.

What I would ask the Government to require

First, that the framework recognise the category. A transaction that satisfies every enforced condition of a standing authority while falling outside what the payer consented to is a distinct thing, and it needs a name before a rule can attach to it. Whether it is treated as authorised, unauthorised, or a third category is a policy judgement I do not presume to make. What I would urge is that it not be left to resolve by default, because on the current evidence base it resolves in favour of whoever holds the record.

Second, that regulation require evidence rather than a mechanism. The framework should not specify how authority is represented or how divergence is detected — that will change, and prescribing it now would fix the wrong design in law. What regulation can properly require is that, where a payment is initiated by software under a delegated authority, the parties be able to produce: the authority under which execution occurred; the evaluation of the proposed transaction against it; and, where the payer was brought back in, what the payer was shown and what they approved. That is a duty about records, which regulation is well suited to impose, rather than a duty about architecture, which it is not.

Third, that where the payer is brought back in, the approval attach to the transaction. A notification asking only “approve?” is materially weaker evidence than an approval bound to the specific transaction, the specific divergence and the specific change being authorised. If a re-authentication is to carry legal weight in allocating loss, it should be possible to say afterwards what it was an approval of.

Fourth, that it be measurable, and that coverage be reported first. Nobody today can say how often agent-initiated payments remain inside the authority that permitted them, because there is no public measure with a defined denominator. Four things would have to be defined before a supervisor, a scheme or a firm could answer that question:

- **Evaluation coverage** — what share of agent-initiated transactions carry sufficient authority and evaluation evidence for conformance to be determinable at all.
- **Mandate conformance** — among evaluable transactions, the share executing without an unapproved divergence from the governing authority.
- **Divergence incidence** — how often execution encounters a material authority mismatch, and of what type: amount, payee, item or service meaning, quantity, cumulative budget, or freshness.
- **Unauthorised continuation** — the share of transaction value moving after an authority evaluation has failed, without a fresh payer authorisation resolving the failure.

Coverage must be reported first. Otherwise a high conformance rate can be produced by excluding every transaction for which no evidence exists, and the measure rewards exactly the firms that record least. I offer these definitions in answer to Question 42.

There is a UK precedent for the shape of this

The Government need not author a technical specification to give one legal effect. The Payment Systems Regulator has twice made a rule book it did not write binding on named institutions. Specific Direction 10 (1 August 2019) required Confirmation of Payee of named entities; Specific Direction 17 (October 2022) expanded it. SD17 requires at §3.2 that “the system must send, and respond to, CoP requests in compliance with the CoP rules and standards,” and defines those at §9.9 as “the rules and standards for CoP in the rule book developed by Pay.UK.”

That is a workable template here: the regulator sets the obligation and the date; a technical body maintains the specification; and the specification remains open for anyone to implement. It also avoids the risk of writing a 2026 architecture into a statutory instrument.

Question 16 — other innovations to take into account

One, and it is the innovation this response is about: **the persistent delegated payment authority** — a standing, machine-readable authority that survives across time and across transactions, and is executed by software against carts the payer has not seen. The lifecycle question is its regulatory consequence rather than a separate topic.

The standards wave of 2025 and 2026 has answered the identity question — which agent is this, is it registered, is its credential scoped — and the evidence question — what did the human sign. It has not answered what happens to a signed authority when reality diverges from it: whether it can be suspended, amended for a single transaction, or superseded with a verifiable link back to what it replaced, and what evidence each of those produces.

The Government’s own proposals make this immediate. Paragraph 4.12 contemplates a new right of access that “could take the form of requiring that, at the request of a PISP, an ASPSP must allow the PISP to **lodge a payment mandate for a series of payment transactions** to be initiated by that PISP.”

That is a proposal to create a statutory right to lodge a standing mandate. I would encourage the Government, in designing it, to settle what happens to that mandate after it is lodged — whether it can be narrowed for a single payment, amended, or superseded with a verifiable link to what it

replaced, and what evidence each of those produces. A right to lodge a mandate with no lifecycle for it inherits the position described under Question 15: an evaluation whose only remedy is destruction, and no record of what the payer agreed to.

I would encourage the Government to treat this as a distinct area rather than folding it into authentication. Authentication asks who is acting. Lifecycle asks whether the authority they are acting under still means what it meant when it was given. Reform aimed only at the first will not reach the second.

Question 17 — supporting an inclusive payments landscape

Paragraph 3.36 identifies consumers and businesses “who may currently be underserved,” and those “who may be more vulnerable to financial harm.” Paragraph 3.37 observes that the opportunities are not automatic. I would offer one specific point, which follows from regulation 75(3) rather than from any assumption about who uses these services.

For a user who delegates because reviewing every transaction is difficult, the evidentiary position is especially important: that user may also find it difficult to examine a confirmation synchronously, or to reconstruct the transaction afterwards from memory. Regulation 75(3) already says that use of the instrument is not in itself necessarily sufficient to prove authorisation — but if no record establishes what the payer agreed to, the practical default becomes that they should have noticed. That is a consequence the inclusion objective in paragraph 3.37 has reason to weigh.

The risk I would flag is therefore not in the capability but in its scope. A framework that carries authority evidence only where the delegate is software would leave arrangements where the delegate is a person with the same evidential gap. Delegation is the fact that matters; whether the delegate is human or machine should not determine whether the payer can later establish what they authorised.

Question 18 — key risks, and how well current regulation addresses them

I address one emerging risk directly relevant to agentic payments, rather than offering a view across the sector-wide scope of this question. It is not fraud in the familiar sense, and it is not separately observable under the current framework, because the framework has no category or reporting measure for it.

Unauthorised continuation — payment value moving after an authority evaluation has failed, with no fresh authorisation resolving the failure — is presently invisible. It is not counted, because there is no requirement to evaluate; not disputed, because the payer cannot demonstrate what they authorised; and not attributed, because no record connects the payment to the authority that permitted it. A harm that cannot be measured or attributed does not become a policy problem until it is large, and by then the architecture that produced it is deployed.

Two documented agent failures illustrate that the risk is not speculative, and they should not be conflated. In a June 2025 test of OpenAI’s Operator on a grocery task, the agent failed to transcribe items accurately — reading the “(5)” after bananas as “15” — omitted an item and added several unchecked ones, a failure of instruction fidelity that occurs before payment begins (Timothy B. Lee, *Understanding AI*, 26 June 2025). In a December 2024 test of Perplexity’s shopping agent, a user’s statement showed a payment to the agent rather than the retailer, and three hours later the agent reported it could not complete the purchase (Maxwell Zeff, *TechCrunch*, 2 December 2024).

Different mechanisms; one shared lesson: **successful-looking execution is not evidence that software stayed inside valid authority.**

On how well the current regulations address it: the provisions are sound and the gap is evidentiary. Regulation 76 obliges a refund where a transaction “was not authorised in accordance with regulation 67,” and the authorised push payment reimbursement perimeter likewise assumes that the authorised-or-not fact can be established after the event. **Both assume a reconstructable record.** What has emerged is not a new fraud typology so much as a new invisibility inside an existing liability split: a category of loss that the rules would allocate correctly if anyone could show what happened, and that nothing currently requires anyone to record.

There is a second-order risk worth naming. Routes to redress already differ materially by payment method — section 75 of the Consumer Credit Act 1974 can make a creditor jointly and severally liable in qualifying debtor-creditor-supplier arrangements, and the authorised push payment reimbursement regime addresses a different category of harm, the Payment Systems Regulator having expressly distinguished reimbursable scams from civil disputes such as goods not received or defective (PS25/5, paragraphs 3.3 and 3.4). Agentic orchestration makes that divergence more consequential, because software may select the payment method on the payer’s behalf. Where protection varies by rail and the choice of rail is delegated, preserving evidence of what the payer authorised matters more, not less.

Question 42 — other feedback

The definitions in this response are offered free and citable. They are published at driftlayer.org/papers/definitions/ as “Four Measures for Mandate Conformance,” and I invite HM Treasury, the FCA, the Payment Systems Regulator, Pay.UK and any firm to use, adapt, test or criticise them, independently of any technical mechanism and of mine in particular. If the Government finds the definitions useful and the mechanism irrelevant, that is a good outcome.

I would add one caution about my own proposal, since it seems better that the Government hears it from me. These measures can be gamed, and the most likely way is through coverage: a firm that records less evidence appears to have a lower divergence rate. That is why coverage must be reported first and why conformance should not be publishable without it. I do not claim the measures are proof against manipulation, only that they are better than the present position, which is no measure and no denominator.

Finally, the FCA has already identified this as work in train — its March 2026 *Regulatory Priorities: Payments* commits it to “work with the Treasury to modernise and future-proof the regulation of payment services and electronic money,” including “considering whether change or development of regulation is needed to support agentic AI payments.” I would encourage that the evidence and measurement questions above be taken up in that work rather than deferred to a later review, because the architectures being deployed now will be expensive to change later.

I would be glad to provide technical detail to the Treasury, the FCA or the Payment Systems Regulator.

References

Payment Services Regulations 2017 (SI 2017/752), regs. 67, 75, 76 and 83.

Merchant Advisory Group, position statement to the W3C workshop on e-commerce agents, September 2026 (position summarised, not quoted).

HM Treasury, Modernising Payment Services Regulation, July 2026 — paragraphs 3.30–3.37 and 4.12; Questions 15–18, 21 and 42.

Visa, Visa Core Rules and Visa Product and Service Rules, §5.7.2.5, public edition dated 18 April 2026.

OpenAI / Stripe, Agentic Commerce Protocol, spec/2026-04-17/openapi/openapi.agentic_checkout.yaml — resolution enum on MessageInfo, MessageWarning and MessageError. Read 13 September 2026.

Universal Commerce Protocol, AP2 Mandates extension, spec version 2026-08-25 — error-code enum including mandate_scope_mismatch.

Google, Agent Payments Protocol specification, docs/ap2/specification.md at release tag v0.2.0 (28 April 2026), commit b4587ac1d055888a73b4b21750973cffba961793 — the release whose own note states it “focuses on providing Human Not Present flows.” Read 13 September 2026.

Aviv, Gandh, Bitton and Shabtai, Beyond the Mandate: A Systematic Security Analysis of the Agent Payments Protocol (AP2), arXiv:2608.23858, 24 August 2026.

Davidovic, S. and Tourpe, H., How Agentic AI Will Reshape Payments, IMF Note 2026/004, April 2026 (cited for its treatment of legal uncertainty and liability; not quoted).

CERT-In, CSIRT-Fin and SISA, Digital Threat Report 2025-26 (BFSI Sector).

Open Banking Limited, Read/Write Standard v4.0 — Domestic VRPs; Domestic Payment Message Formats.

NatWest, “How do I amend a VRP (variable recurring payment) or sweeping payment?”, published customer guidance.

Financial Conduct Authority, Regulatory Priorities: Payments, March 2026.

Payment Systems Regulator, Specific Direction 10, 1 August 2019 (PS19/4); Specific Direction 17, October 2022.

Payment Systems Regulator, PS25/5, APP scams reimbursement — consolidated policy statement, May 2025, paragraphs 3.3–3.4.

Consumer Credit Act 1974, section 75.

Lee, T. B., “Computer-use agents seem like a dead end,” Understanding AI, 26 June 2025.

Zeff, M., “The race is on to make AI agents do your online shopping for you,” TechCrunch, 2 December 2024.

Kirby, M. T., Mandate Lifecycle Extensions for Agentic Payment Credentials, Technical Disclosure Commons, Defensive Publications Series no. 11517, August 2026, CC BY 4.0.

Four Measures for Mandate Conformance, driftlayer.org/papers/definitions/.